

CO3 - ASSESSMENT TOOL - 2

PORT SCANNING CHALLENGE

Question 1

How would you identify and prioritize vulnerabilities after discovering multiple open ports during a port scan? Explain your approach.

Answer:

After discovering multiple open ports, I would first identify the services running on those ports and then evaluate their vulnerabilities based on severity, exposure, exploitability, and business impact.

Approach:

1. **Service Identification**

Identify the service and version associated with each open port.

2. **Vulnerability Identification**

Check the identified services against trusted sources such as CVE databases, NVD, and vendor security advisories.

3. **Risk Assessment**

Consider:

- Severity of the vulnerability
- Ease of exploitation
- Whether the service is Internet-facing
- Sensitivity of the data handled
- Potential business impact

4. **Prioritization**

Critical and high-risk vulnerabilities should be addressed first, especially when they are publicly exposed and easily exploitable.

Example:

Open Port	Service	Possible Risk	Priority
22	SSH	Brute-force/weak authentication	High
21	FTP	Unencrypted credentials/data	High
80/443	Web Server	Web application vulnerabilities	Medium/High
3306	MySQL	Unauthorized database access	Critical

Therefore, I would prioritize vulnerabilities based on:

$$\text{Risk} = \text{Likelihood of Exploitation} \times \text{Potential Impact}$$

This ensures that the most dangerous vulnerabilities are remediated first rather than treating every open port equally.

Question 2

A SYN scan and a TCP Connect scan produce different results on the same target. What factors could cause this difference, and how would you verify the findings?

Answer:

A SYN scan and a TCP Connect scan use different methods to determine whether a TCP port is available. Therefore, differences in their results can occur because of network security mechanisms or network conditions.

Factors causing different results:

1. Firewall rules may treat SYN packets and complete TCP connections differently.
2. IDS/IPS systems may detect and interfere with scanning traffic.
3. Host-based firewalls may selectively filter connection attempts.
4. Network congestion or packet loss may cause inconsistent results.
5. Rate limiting may temporarily block repeated scan attempts.
6. The service may behave differently when a complete connection is established.

Verification:

I would verify the results by:

- Repeating the scan under the same network conditions.
- Performing a normal TCP connection test on the specific port.
- Using service/version detection where authorized.
- Checking firewall and IDS/IPS logs.
- Using packet capture tools such as Wireshark.
- Comparing results from another authorized network location.

For example, if a SYN scan identifies port 443 as open but a TCP Connect scan reports it as filtered, I would investigate whether a firewall or security device is interfering with the connection.

Thus, the difference between the scans should be investigated rather than assuming that one scan is automatically incorrect.

Question 3

During a port scan, most ports appear as "filtered." What security mechanisms might be responsible, and what additional techniques would you use to gather more information?

Answer:

A port marked as "filtered" generally means that the scanner cannot determine whether the port is open because network traffic is being blocked or dropped.

Possible security mechanisms:

- Network firewalls
- Host-based firewalls
- Intrusion Prevention Systems (IPS)
- Intrusion Detection Systems (IDS)
- Access Control Lists (ACLs)
- Cloud security groups
- Network segmentation

- VPN gateways
- Rate-limiting mechanisms

For example, a firewall may silently drop incoming packets instead of sending a response. As a result, the scanner reports the port as filtered.

Additional techniques:

1. TCP verification
Check selected ports using legitimate TCP connection attempts.
2. UDP scanning
Identify services that operate through UDP, such as DNS and SNMP.
3. Service detection
Determine the service running on accessible ports.
4. Packet analysis
Use Wireshark to determine whether packets are being dropped, rejected, or modified.
5. Security log analysis
Examine firewall and IDS/IPS logs if access is available.
6. Different authorized network locations
Compare results from internal and external locations to understand network segmentation.

A large number of filtered ports may indicate effective security controls, but filtering alone does not prove that the underlying services are secure.

Question 4

Compare TCP, UDP, and stealth (SYN) port scanning techniques. In which scenarios would each be the most effective, and what are their advantages and limitations?

Answer:

TCP, UDP, and SYN scans are different techniques used to discover network services.

1. TCP Connect Scan

Scan Type	Working	Best Used For	Advantages	Limitations
TCP Connect	Completes TCP handshake	Confirming TCP connectivity	Reliable and simple	More visible to monitoring systems
SYN Scan	Sends SYN and analyzes response without normally completing connection	Fast TCP discovery	Fast and efficient	Can still be detected
UDP Scan	Sends UDP probes	Finding UDP services	Finds services missed by TCP scans	Slower and responses may be limited

A TCP Connect scan completes the normal TCP three-way handshake:

SYN → SYN/ACK → ACK

It is useful when a reliable confirmation of TCP connectivity is required.

Advantage:

- Simple and reliable.

Limitation:

- Establishes a complete connection and can therefore be more easily logged or detected.

2. SYN Scan

A SYN scan sends a SYN packet and analyzes the response without normally completing the connection.

Simplified process:

SYN → SYN/ACK → RST

It is effective for quickly identifying TCP services during an authorized security assessment.

Advantages:

- Fast
- Efficient
- Less connection overhead

Limitation:

- Requires suitable privileges/tools and can still be detected by modern security systems.

3. UDP Scan

UDP scanning is used to identify services that operate over UDP.

Examples include:

- DNS
- SNMP
- DHCP
- Some VPN services

Advantage:

- Can discover services that TCP scans cannot identify.

Limitations:

- Generally slower
- Many UDP services do not respond to probes, making results harder to interpret.

Therefore, using TCP/SYN and UDP scanning together provides a more complete assessment.

Question 5

Suppose you are conducting an authorized security assessment and discover critical services such as SSH, FTP, and database ports exposed to the Internet. How would you assess the risks and recommend mitigation strategies?

Answer:

Internet-facing SSH, FTP, and database services increase the organization's attack surface. I would assess each service separately based on its configuration, vulnerabilities, authentication mechanisms, and business importance.

1. SSH – Port 22

Possible risks:

- Brute-force attacks
- Weak passwords
- Outdated SSH software
- Unauthorized user access

Recommended mitigation:

- Use strong key-based authentication.
- Enable MFA where possible.
- Disable direct root login.
- Restrict SSH access to trusted IP addresses or VPN users.
- Keep the SSH service updated.
- Monitor failed login attempts.

2. FTP – Port 21

Possible risks:

- Credentials and data may be transmitted insecurely.
- Weak authentication can lead to unauthorized access.
- Outdated FTP software may contain vulnerabilities.

Recommended mitigation:

- Disable FTP if it is not required.
- Replace traditional FTP with SFTP or another secure file-transfer protocol.
- Use strong authentication.
- Restrict access to trusted networks.
- Monitor file-transfer activity.

3. Database Ports

Examples include:

- MySQL – 3306
- PostgreSQL – 5432
- Microsoft SQL Server – 1433

Possible risks:

- Unauthorized database access
- Data theft
- Data modification or deletion
- Exploitation of outdated database software
- Weak or default credentials

Recommended mitigation:

- Avoid exposing databases directly to the Internet.
- Place databases inside a private network.
- Allow access only from approved application servers.
- Use firewall rules and security groups.
- Apply least-privilege permissions.
- Use strong authentication.
- Encrypt database connections.
- Keep database software patched.
- Maintain regular backups.

Risk Prioritization:

Service	Risk Level	Reason
Internet-facing database	Critical	Direct access to sensitive data
Insecure FTP	High	Possible credential/data exposure
Unrestricted SSH	High	Brute-force and unauthorized access
Properly secured SSH	Medium/Low	Strong authentication reduces risk

Overall Recommendation:

The organization should follow the principle of minimizing unnecessary Internet exposure.

The recommended security approach is:

Reduce Exposure → Patch Services → Strengthen Authentication → Restrict Access → Monitor Continuously

The final assessment report should include the affected port, service, vulnerability, risk level, potential impact, evidence, and recommended mitigation.

Conclusion

Port scanning is an important part of network security assessment, but identifying open ports is only the first step. A complete assessment should identify the services, analyze vulnerabilities, verify scan results, determine the level of exposure, and evaluate the possible business impact.

By combining different scanning techniques and applying risk-based prioritization, security professionals can identify the most critical weaknesses and recommend effective mitigation strategies. This approach converts technical scan results into practical security improvements.